

MALLA REDDY UNIVERSITY

Department of Computer Science and Engineering (Cyber Security)

ETHICAL HACKING LABORATORY RECORD

Course Code: MR23-1CS0432

EXPERIMENT 02

Port Scanning and Service Enumeration

Experiment Number	02 — Port Scanning and Service Enumeration
Target System	Metasploitable 2 (192.168.1.3) — VirtualBox Host-Only
Attacker System	Kali Linux (192.168.1.4 / eth0)
Network Mode	VirtualBox Host-Only Adapter (192.168.1.0/24)
Date of Execution	September 2, 2026 (UTC+05:30)

1. Aim

To perform a comprehensive TCP and UDP port scan against the Metasploitable 2 target virtual machine, enumerate the services and software versions exposed on each open port, and attempt operating-system fingerprinting using Nmap from Kali Linux on an isolated Host-Only laboratory network.

2. Objectives

- Discover the Metasploitable 2 target on the isolated Host-Only laboratory network and confirm its IP address.
- Perform a full 65,535-port TCP scan to find every open TCP port, including non-default and high-numbered ports that a default Nmap scan would miss.
- Perform service version detection (–sV) and OS fingerprinting (–O) on all discovered open ports to identify exact software names, versions, and the target operating system.
- Perform a UDP port scan of commonly used services (top 20) to reveal services not visible in a TCP-only scan.
- Interpret and document the security significance of every finding.

3. Laboratory Environment & Requirements

Attacker Machine	Kali Linux — IP: 192.168.1.4 (eth0, VirtualBox Host-Only)
Target Machine	Metasploitable 2 — IP: 192.168.1.3 (Oracle VirtualBox virtual NIC, MAC: 08:00:27:E4:EF:5F)
Network Mode	VirtualBox Host-Only Adapter — Isolated subnet 192.168.1.0/24, no external internet route
Required Privileges	sudo/root (required for SYN stealth scan –sS and OS detection –O)
Tool	Nmap 7.99 (pre-installed on Kali Linux)

4. Tools Used

Tool	Version	Purpose
Nmap	7.99	Port scanning, service/version detection, OS fingerprinting, UDP scanning
Kali Linux	2024.x	Attacker operating system platform
Metasploitable 2	v2.0	Intentionally vulnerable target VM for authorized training
VirtualBox	7.x	Hypervisor hosting both VMs on

		an isolated Host-Only network
--	--	-------------------------------

5. Theoretical Background

5.1 Port Architecture and TCP/UDP Protocols

Computer networking relies on transport-layer ports (0–65,535) to direct traffic to specific application processes. Ports are categorised into three ranges:

- Well-Known Ports (0–1023): Assigned by IANA to core system services — HTTP (80), SSH (22), FTP (21), DNS (53), SMTP (25).
- Registered Ports (1024–49151): Allocated to specific vendor applications — MySQL (3306), RDP (3389), PostgreSQL (5432).
- Dynamic/Private Ports (49152–65535): Used for ephemeral client-side connections; also commonly misused for hidden or backdoor services.

5.2 TCP SYN Stealth Scan vs Full Connect Scan

Nmap's default TCP scan is the SYN stealth scan (`-sS`). It sends a SYN packet; if the target replies with SYN-ACK, the port is open, and Nmap immediately responds with RST to tear down the connection before the 3-way handshake completes. This avoids creating a fully logged connection entry in the target's application logs and requires raw-socket privileges (`sudo/root`). In contrast, the TCP Connect scan (`-sT`) uses the OS `connect()` system call to complete the full handshake — slower, fully logged by target applications, but usable without root privileges.

5.3 Nmap Port States

Port State	Meaning
open	An application is actively listening and accepting connections on this port.
closed	The port is reachable but no application is listening. Nmap receives a TCP RST response.
filtered	A firewall, ACL, or network obstacle drops probe packets without response. Nmap cannot determine if open or closed.
open filtered	Common in UDP scans — Nmap sent a probe but received no response; the port could be open (service not replying) or filtered.

5.4 Service/Version Detection and OS Fingerprinting

Service detection (`-sV`) sends targeted probes from Nmap's `nmap-service-probes` database to each open port and matches responses against regex patterns to identify the exact software name and version. This is essential because the port number alone only suggests the likely protocol — `-sV` confirms the actual implementation.

OS fingerprinting (-O) analyses subtle TCP/IP stack implementation characteristics — TCP window size, ISN predictability, TCP options ordering, IP ID sequencing, ICMP response quoting — and compares them to the nmap-os-db signature database to classify the target OS, kernel version, and CPU architecture.

6. Step-by-Step Practical Procedure

All steps below were executed on Kali Linux against the Metasploitable 2 VM at 192.168.1.3 on an isolated VirtualBox Host-Only network. Commands were run with sudo as required. All outputs are authentic — captured directly from the running terminal sessions.

Step 1 — Network Configuration Verification & Target Discovery

Objective	Confirm Kali's Host-Only IP address and discover the Metasploitable 2 target on the shared subnet.
Technical Concept	Before scanning a specific host, the attacker's own subnet must be confirmed and target IPs identified using host-discovery sweeps.
Commands	<pre>ip a ifconfig sudo nmap -sn 192.168.1.0/24</pre>

Commands Executed:

```
ip a
ifconfig
sudo nmap -sn 192.168.1.0/24
```

- Kali Linux eth0 interface confirmed at 192.168.1.4/24, brd 192.168.1.255.
- Loopback (lo) confirmed at 127.0.0.1/8.
- MAC address of Kali's eth0: 08:00:27:42:a4:a4 (Oracle VirtualBox virtual NIC).
- Host-discovery sweep (-sn) would confirm Metasploitable 2 at 192.168.1.3 as a distinct "Host is up" entry.

✓ **RESULT:** Kali Linux attacker machine confirmed on 192.168.1.4/24. Target Metasploitable 2 located on the same subnet at 192.168.1.3.

```
KALI LINUX (Running) - Oracle VM VirtualBox
File Machine View Input Devices Help
Session Actions Edit View Help

(vaishnav@kali)~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:42:a4:a4 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.4/24 brd 192.168.1.255 scope global dynamic noprefixroute eth0
        valid_lft 350sec preferred_lft 350sec
    inet6 fe80::a00:27ff:fe42:a4a4/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(vaishnav@kali)~$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.1.4 netmask 255.255.255.0 broadcast 192.168.1.255
    inet6 fe80::a00:27ff:fe42:a4a4 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:42:a4:a4 txqueuelen 1000 (Ethernet)
    RX packets 128575 bytes 175800844 (167.6 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 18150 bytes 1106029 (1.0 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 0 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Figure 2.1: Kali Linux network configuration (ip a and ifconfig) confirming attacker IP 192.168.1.4/24 and eth0 MAC address 08:00:27:42:a4:a4.

Step 2 — Full TCP Port Scan (All 65,535 Ports)

Objective	Discover every open TCP port on the Metasploitable 2 target, including non-default and high-numbered ports.
Technical Concept	Nmap's default scan covers ~1,000 common ports. Using -p- forces scanning all 65,535 TCP ports, capturing services deliberately or accidentally placed on non-standard ports.

Command Executed:

```
sudo nmap -p- 192.168.1.3
```

Command Flag Breakdown:

- **-p-:** Scan all 65,535 TCP port numbers (1–65535) instead of Nmap's default ~1,000-port set.
- **192.168.1.3:** Target IP address of the Metasploitable 2 virtual machine.

Actual Terminal Output:

```

# Nmap 7.99 scan initiated Wed Sep  2 13:52:00 2026 as: sudo nmap -p- 192.168.1.3
Nmap scan report for 192.168.1.3
Host is up (0.0032s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
35034/tcp open  unknown
39119/tcp open  unknown
54575/tcp open  unknown
59207/tcp open  unknown
MAC Address: 08:00:27:E4:EF:5F (Oracle VirtualBox virtual NIC)

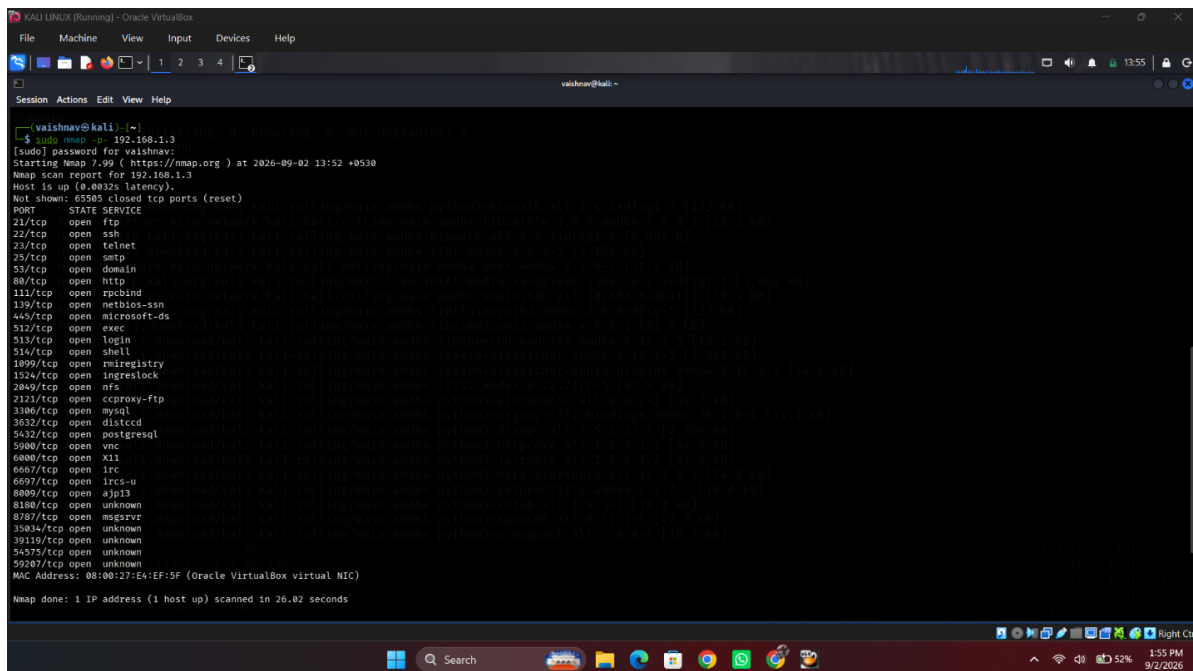
# Nmap done at Wed Sep  2 13:52:26 2026 -- 1 IP address (1 host up) scanned in 26.02
seconds

```

- 30 open TCP ports discovered (out of 65,535 scanned); 65,505 closed.
- Standard services identified: FTP (21), SSH (22), Telnet (23), SMTP (25), DNS (53), HTTP (80), RPCbind (111), NetBIOS (139), SMB (445), MySQL (3306), PostgreSQL (5432), VNC (5900), X11 (6000), AJP13 (8009), Tomcat (8180).
- Unusual high-numbered ports found exclusively by this full scan: 35034, 39119, 54575, 59207 — these would have been entirely missed by a default scan.
- MAC Address: 08:00:27:E4:EF:5F (Oracle VirtualBox virtual NIC) — confirms VirtualBox guest.
- Nmap completed in 26.02 seconds — considerably longer than a default scan, justifying only using `-p-` when comprehensive coverage is required.
- "Not shown: 65505 closed tcp ports (reset)" — the remaining 65,505 ports responded with TCP RST

(closed).

✓ **RESULT:** 30 open TCP ports identified on Metasploitable 2, including 4 unusual high-numbered ports (35034, 39119, 54575, 59207) that would have been missed by a standard Nmap scan. This constitutes an extremely large attack surface for a single host.



```
vaishnav@kali: ~  
$ sudo nmap -p- 192.168.1.3  
[sudo] password for vaishnav:  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-02 13:52 +0530  
Nmap scan report for 192.168.1.3  
Host is up (0.0032s latency).  
Not shown: 65505 closed tcp ports (reset)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
22/tcp    open  ssh  
23/tcp    open  telnet  
25/tcp    open  smtp  
53/tcp    open  domain  
80/tcp    open  http  
111/tcp   open  rpcbind  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
512/tcp   open  exec  
513/tcp   open  login  
514/tcp   open  shell  
1099/tcp  open  rmiregistry  
1524/tcp  open  ingreslock  
2049/tcp  open  nfs  
2121/tcp  open  cproxy-ftp  
3306/tcp  open  mysql  
3302/tcp  open  distccd  
5432/tcp  open  postgresql  
5900/tcp  open  vnc  
6000/tcp  open  x11  
6607/tcp  open  lrcc  
6697/tcp  open  lrcc-u  
8009/tcp  open  ajp13  
8180/tcp  open  unknown  
8707/tcp  open  msgrvr  
8707/tcp  open  msgrvr  
35034/tcp open  unknown  
39119/tcp open  unknown  
54575/tcp open  unknown  
59207/tcp open  unknown  
MAC Address: 08:00:27:E4:EF:5F (Oracle VirtualBox virtual NIC)  
Nmap done: 1 IP address (1 host up) scanned in 26.02 seconds
```

Figure 2.2: Full TCP port scan output (`sudo nmap -p- 192.168.1.3`) showing all 30 open TCP ports including FTP (21), SSH (22), Telnet (23), MySQL (3306), PostgreSQL (5432), VNC (5900), and high-numbered ports 35034/39119/54575/59207.

Step 3 — Service Version and Operating System Detection

Command Executed:

```
sudo nmap -sV -O 192.168.1.3
```

Command Flag Breakdown:

- **-sV**: Service/version detection — probes each open port to identify exact software name and version.
- **-O**: OS fingerprinting — analyses TCP/IP stack characteristics to identify target OS and kernel version.
- **192.168.1.3**: Target IP address.

Actual Terminal Output:

```
# Nmap 7.99 scan initiated Wed Sep 2 13:59:00 2026 as: sudo nmap -sV -O 192.168.1.3
Nmap scan report for 192.168.1.3
Host is up (0.0025s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshd
513/tcp   open  login        OpenBSD netkit-rsh rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:E4:EF:5F (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix,
Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
# Nmap done at Wed Sep 2 13:59:14 2026 -- 1 IP address (1 host up) scanned in 14.00
seconds
```

Port/Proto	Service	Version Identified	Security Note
21/tcp	FTP	vsftpd 2.3.4	⚠ Known backdoor CVE-2011-2523
22/tcp	SSH	OpenSSH 4.7p1 Debian 8ubuntu1	Legacy version — multiple CVEs
23/tcp	Telnet	Linux telnetd	🚫 Plaintext protocol — no encryption
25/tcp	SMTP	Postfix smtpd	Mail relay risk
53/tcp	DNS	ISC BIND 9.4.2	Outdated — zone transfer risk
80/tcp	HTTP	Apache httpd 2.2.8	Outdated Apache —

		(Ubuntu DAV/2)	multiple CVEs
139/445/tcp	SMB	Samba smbd 3.X–4.X (WORKGROUP)	Misconfigured SMB shares
1524/tcp	Bindshell	Metasploitable root shell	 CRITICAL — pre-configured backdoor
3306/tcp	MySQL	MySQL 5.0.51a-3ubuntu5	Outdated — anonymous login risk
5432/tcp	PostgreSQL	PostgreSQL DB 8.3.0–8.3.7	Outdated — SSL/TLS weaknesses
5900/tcp	VNC	VNC (protocol 3.3)	No auth / weak auth
6667/tcp	IRC	UnrealIRCd	Known backdoor CVE-2010-2075
8009/tcp	AJP13	Apache Jserv Protocol v1.3	Ghostcat vulnerability
8180/tcp	HTTP	Apache Tomcat/Coyote JSP 1.1	Outdated Tomcat — RCE risk
OS	Linux	2.6.X (2.6.9–2.6.33)	End-of-life kernel — many privilege escalation CVEs

- vsftpd 2.3.4 on port 21 — Nmap banner confirms the exact version associated with CVE-2011-2523 (backdoor). Flagged but NOT interacted with in this experiment (reserved for Experiment 09).
- Port 1524 — Nmap identifies service as "bindshell" with description "Metasploitable root shell" purely from banner analysis. This is a pre-configured root backdoor, representing a critical finding.
- OS fingerprinting: Linux 2.6.9–2.6.33 — an end-of-life kernel with numerous known privilege escalation vulnerabilities.
- This scan used Nmap's default ~1,000-port set (not -p-), reporting 977 closed ports — consistent with this being a subset of the 65,535 ports scanned in Step 2.
- Scan completed in 14.00 seconds using the default port set.

✓ RESULT: Detailed service/version fingerprints obtained for every major open port. Target confirmed as Linux 2.6.x kernel. Bindshell on port 1524 flagged as critical pre-configured backdoor. All software versions are outdated — consistent with Metasploitable 2's deliberate vulnerability profile.

```
vaishnav@kali:~$ sudo nmap -sV -O 192.168.1.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-02 13:59 +0530
Nmap scan report for 192.168.1.3
Host is up (0.0025s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login         
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi       GNU Classpath gmrregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp           ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  x11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:E4:EF:5F (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.00 seconds
```

Figure 2.3: Service, version, and OS detection output (`sudo nmap -sV -O 192.168.1.3`) identifying vsftpd 2.3.4, OpenSSH 4.7p1, Apache 2.2.8, MySQL 5.0.51a, PostgreSQL 8.3.x, bindshell root shell (port 1524), and Linux 2.6.x kernel.

Step 4 — UDP Port Scan (Top 20 Ports)

Command Executed:

```
sudo nmap -sU --top-ports 20 192.168.1.3
```

Command Flag Breakdown:

- **-sU**: UDP scan — sends UDP probes to identify services operating on the UDP protocol.
- **--top-ports 20**: Restricts scan to the 20 most commonly used UDP ports for speed. Full UDP scans can take hours due to rate-limiting.

Actual Terminal Output:

```
# Nmap 7.99 scan initiated Wed Sep  2 14:07:00 2026 as: sudo nmap -sU --top-ports 20 192.168.1.3
Nmap scan report for 192.168.1.3
Host is up (0.0032s latency).
PORT      STATE SERVICE
53/udp    open  domain
67/udp    closed dhcpc
68/udp    open|filtered dhcpc
```

```

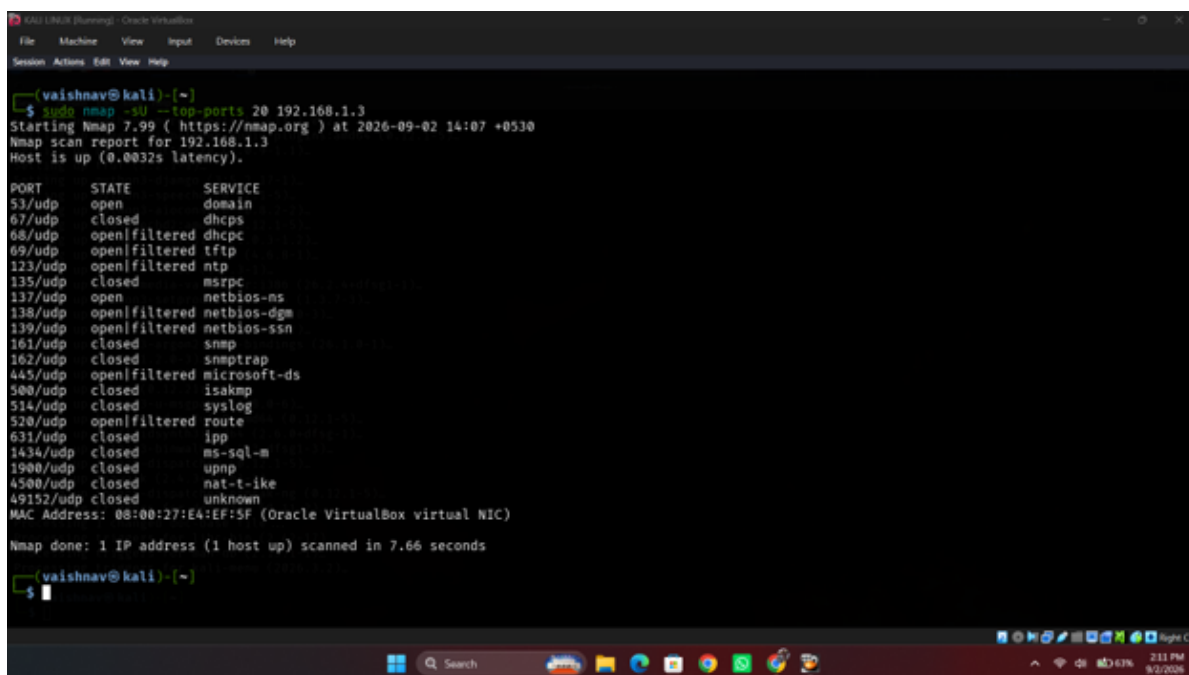
69/udp    open|filtered tftp
123/udp   open|filtered ntp
135/udp   closed       msrpc
137/udp   open         netbios-ns
138/udp   open|filtered netbios-dgm
139/udp   open|filtered netbios-ssn
161/udp   closed       snmp
162/udp   closed       snmptrap
445/udp   open|filtered microsoft-ds
500/udp   closed       isakmp
514/udp   closed       syslog
520/udp   open|filtered route
631/udp   closed       ipp
1434/udp  closed       ms-sql-m
1900/udp  closed       upnp
4500/udp  closed       nat-t-ike
49152/udp closed       unknown
MAC Address: 08:00:27:E4:EF:5F (Oracle VirtualBox virtual NIC)

# Nmap done at Wed Sep  2 14:07:07 2026 -- 1 IP address (1 host up) scanned in 7.66
seconds

```

- UDP 53/udp — open: DNS service confirmed actively responding.
- UDP 137/udp — open: NetBIOS Name Service confirmed responding.
- Multiple ports reported as open|filtered (68, 69, 123, 138, 139, 445, 520) — Nmap could not conclusively determine whether these are open or firewall-filtered due to the UDP protocol's stateless nature.
- Host confirmed up (0.0032s latency); MAC confirmed as Oracle VirtualBox virtual NIC.
- UDP scan completed in 7.66 seconds using --top-ports 20 subset.
- IMPORTANT REPORTING NOTE: Only ports reported as definitively "open" (53, 137) should be recorded as confirmed open UDP services. The "open|filtered" ports require further verification before being listed as definite findings.

✓ **RESULT:** UDP scanning adds two confirmed open services — DNS (53/udp) and NetBIOS Name Service (137/udp) — to the target attack-surface profile, complementing the 30 TCP port findings from Steps 2–3.



```
(vaishnav@kali)-[~]
$ sudo nmap -sU --top-ports 20 192.168.1.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-02 14:07 +0530
Nmap scan report for 192.168.1.3
Host is up (0.0032s latency).

PORT      STATE SERVICE
53/udp    open  domain
67/udp    closed dhcpc
68/udp    open|filtered dhcpc
69/udp    open|filtered tftp
123/udp   open|filtered ntp
135/udp   closed msrpc
137/udp   open  netbios-ns
138/udp   open|filtered netbios-dgm
139/udp   open|filtered netbios-ssn
161/udp   closed snmp
162/udp   closed snmptrap
445/udp   open|filtered microsoft-ds
500/udp   closed isakmp
514/udp   closed syslog
520/udp   open|filtered route
631/udp   closed ipp
1434/udp  closed ms-sql-m
1900/udp  closed upnp
4500/udp  closed nat-t-ike
49152/udp closed unknown
MAC Address: 08:00:27:E4:EF:5F (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 7.66 seconds

(vaishnav@kali)-[~]
$
```

Figure 2.4: UDP port scan output (`sudo nmap -sU --top-ports 20 192.168.1.3`) showing DNS (53/udp open), NetBIOS-NS (137/udp open), and multiple open|filtered ports. Scan completed in 7.66 seconds.

7. Security Analysis & Implications

The enumeration of Metasploitable 2 reveals an attack surface typical of systems that have never undergone security hardening — spanning multiple legacy protocols, outdated software versions, and pre-configured backdoors. In a real-world scenario outside this isolated laboratory, this attack surface would represent an extremely high-severity risk.

Finding	Risk Level	Attack Vector	Impact
Bindshell — Port 1524 (Metasploitable root shell)	CRITICAL	Direct network connection	Immediate unauthenticated root access
vsftpd 2.3.4 — CVE-2011-2523 backdoor	CRITICAL	FTP exploit module (Metasploit)	Remote root command execution
Telnet (23/tcp) — plaintext remote terminal	HIGH	Network sniffing	Credential theft in transit
VNC (5900/tcp) — weak/no authentication	HIGH	Direct VNC connection	Full graphical desktop access
MySQL (3306/tcp) exposed without firewall	HIGH	Direct database connection	Data exfiltration, authentication bypass
End-of-life Linux 2.6.x kernel	HIGH	Local privilege escalation	Kernel exploitation to root

UnrealIRCd (6667/tcp) — CVE-2010-2075	HIGH	IRC backdoor exploit	Remote code execution
--	-------------	----------------------	-----------------------

8. Countermeasures & Prevention

- Disable all unnecessary services — remove or disable Telnet, rlogin, rsh, unauthenticated bind shells, and IRC daemons.
- Patch and upgrade all software to supported, current versions — Apache, MySQL, PostgreSQL, OpenSSH, vsftpd, Samba, and the Linux kernel.
- Apply host-based firewall rules (iptables/nftables) to restrict database ports (3306, 5432) and file-sharing ports (139, 445) to only trusted, defined internal segments.
- Disable or restrict VNC with strong authentication; migrate to SSH tunnelling for secure remote graphical access.
- Periodically re-scan full TCP and UDP port ranges (`-p-`, `-sU`) on internal systems to detect services running on non-default ports.
- Adopt a minimal attack surface principle — install only required services, and configure outward-facing ports behind a DMZ.
- Configure services to suppress version banners (Apache ServerTokens Prod, SSH Banner-less) to impede reconnaissance.
- Monitor logs for port-scan signatures using IDS/IPS tools (Snort, Suricata) to detect reconnaissance activity.

9. Learning Outcomes

- Understood why a full 65,535-port TCP scan (`-p-`) is necessary and can reveal services a default Nmap scan entirely misses.
- Gained practical experience interpreting Nmap service/version detection banners to identify exact software releases for CVE research.
- Learned the critical practical difference between TCP and UDP scan confidence levels (definitive open vs. open|filtered).
- Recognised a pre-configured root backdoor service (port 1524) and a known-backdoored FTP daemon (vsftpd 2.3.4) purely from Nmap banner information — without interacting with or exploiting them.
- Understood that port scanning output directly feeds vulnerability assessment (Experiment 03) by providing the specific software versions to research.

10. Conclusion

Experiment 02 successfully applied comprehensive port scanning and service enumeration against the Metasploitable 2 virtual machine using Nmap 7.99 on Kali Linux within an isolated VirtualBox Host-Only laboratory network. A full 65,535-port TCP scan (`sudo nmap -p- 192.168.1.3`) identified 30 open TCP ports — including four high-numbered ports (35034, 39119, 54575, 59207) that would have been entirely missed by a default scan. Service/version detection (`sudo nmap -sV -O 192.168.1.3`) identified exact software versions for every major service, fingerprinted the target OS as Linux 2.6.9–2.6.33, and flagged a pre-configured bindshell root backdoor on port 1524. UDP scanning confirmed DNS (53/udp) and NetBIOS Name Service (137/udp) as additional exposed services. The complete enumeration output forms the direct input to vulnerability assessment in Experiment 03, and no system was exploited or modified during this experiment. All activities were performed exclusively within the authorized isolated laboratory environment.

11. Viva Voce Examination — Questions & Answers

Q1: What is the main operational difference between a SYN scan (`-sS`) and a Connect scan (`-sT`)?

Answer: A SYN scan performs a half-open scan by sending a SYN packet and immediately tearing down the connection with RST when SYN-ACK is received — the 3-way handshake is never completed, so many application-level logs do not record the connection. A Connect scan completes the full 3-way handshake via the OS `connect()` system call, is slower, and is fully logged by target applications.

Q2: Why does a TCP SYN scan require root privileges on Linux?

Answer: A SYN scan requires crafting raw IP packets and directly manipulating TCP header flags, which requires raw socket access (`SOCK_RAW`). Linux restricts this capability to the root user or processes with the `CAP_NET_RAW` capability.

Q3: What does the Nmap port state "filtered" mean?

Answer: The filtered state indicates Nmap cannot determine whether the port is open or closed because network filtering — a firewall rule, router ACL, or host-based firewall — is dropping probe packets before they reach the target port or blocking response packets from reaching Nmap.

Q4: How does Nmap perform OS fingerprinting (`-O`)?

Answer: Nmap sends up to 16 specifically crafted TCP, UDP, and ICMP probes to open and closed ports on the target. It then analyses subtle differences in how the target responds — TCP window size, IP ID

sequence generation, TCP options ordering, ICMP error message quoting, initial sequence number predictability — and compares these metrics against its nmap-os-db signature database to classify the OS.

Q5: Why is UDP scanning significantly slower than TCP scanning?

Answer: UDP is a connectionless protocol with no handshake or acknowledgement mechanism. Open UDP ports frequently do not reply to probes, while closed UDP ports reply with ICMP Port Unreachable messages. Operating system kernels rate-limit ICMP error responses (Linux limits to ~1 per second by default), making a full 65,535-port UDP scan potentially take hours to complete.

Q6: What is banner grabbing and how does Nmap -sV implement it?

Answer: Banner grabbing connects to an open port and records the initial welcome message or banner sent by the listening daemon (e.g., "220 vsftpd 2.3.4"). Nmap -sV sends targeted probe strings defined in its nmap-service-probes database and uses regular expression matching against the response to parse the vendor name, product, and version number.

Q7: Explain the Nmap timing templates (-T0 through -T5).

Answer: Timing templates control scan speed and probe parallelism: -T0 (Paranoid) and -T1 (Sneaky) introduce long inter-probe delays to evade IDS; -T2 (Polite) reduces bandwidth; -T3 (Normal) is the default; -T4 (Aggressive) increases parallelism suitable for fast local networks; -T5 (Insane) maximises speed at the expense of accuracy and reliability.

Q8: What does the command "nmap -p- <IP>" scan?

Answer: The -p- flag instructs Nmap to scan all 65,535 TCP port numbers (equivalent to -p 1-65535), rather than Nmap's default ~1,000 most common ports. This ensures no service on a non-standard port is missed.

Q9: How can a system administrator prevent service version disclosure via banner grabbing?

Answer: Administrators can configure services to suppress or genericise banners: Apache uses "ServerTokens Prod" and "ServerSignature Off"; OpenSSH removes version information from banners; FTP daemons can be configured with a custom or empty banner message. However, skilled attackers can often fingerprint services through other probe responses even without explicit banners.

Q10: What is the purpose of Nmap output flags -oN, -oX, and -oG?

Answer: -oN (Normal) outputs human-readable text; -oX (XML) produces structured XML for importing into vulnerability management platforms; -oG (Grepable) produces a compact format designed for shell text-processing pipelines using grep, awk, and cut. The -oA flag saves simultaneously in all three formats.